

Users, Profiles & Anti-Scam KYC Schema Specification

Zero-Trust Identity, Privilege Escalation Firewall & Landlord Verification Architecture

Jira Reference: SCRUM-54

Database Engine: PostgreSQL 15+ (Supabase)

Status: **APPROVED / DONE**

Lead Architect: Squad Lead Orchestrator

Engineer: Senior Fullstack Engineer

Auditor: Senior Dev Auditor

GitHub Repository Source: github.com/hermarDev/Abang_Cebu_AI_Group2/blob/main/docs/users-and-profiles-schema.md

1. Executive Summary & Design Pillars

In the AbangCebuAI platform, the identity and trust infrastructure forms the foundation for every downstream real estate operation, including listing creation, AI rental search, landlord verification, and booking inquiries.

- **Strict Auth/Domain Separation (Zero-Trust Identity):** Supabase internal `auth.users` holds credentials and tokens. Application code interacts solely with `public.profiles` via `id UUID PRIMARY KEY REFERENCES auth.users(id) ON DELETE CASCADE`.
- **Anti-Privilege Escalation Firewall:** Malicious attempts to inject `role: 'admin'` in public registration metadata are intercepted by `handle_new_user()` and clamped to `'renter'`. Role mutations are blocked in RLS.
- **Anti-Scam Trust Layer (Landlord KYC):** Metro Cebu renters face rampant rental scams on unmoderated social platforms. The `kyc_verifications` table requires verified Philippine IDs and proof-of-ownership before listings can attain public approval.
- **Search Path Sanitization:** All `SECURITY DEFINER` functions specify `SET search_path = public, auth, extensions`, mitigating CVE-class schema poisoning vulnerabilities.
- **Deterministic TypeScript Contracts:** Schema mirrored in `src/types/database.ts` with zero TypeScript errors.

2. Custom Enumerations

Enum Name	Values	Description
<code>public.user_role</code>	<code>'renter', 'landlord', 'admin'</code>	Defines system roles. Unauthenticated visitors interact via anon role.
<code>public.kyc_status</code>	<code>'pending', 'verified', 'rejected'</code>	Tracks verification lifecycle of landlord identification.
<code>public.kyc_id_type</code>	<code>'passport', 'philsys_id', 'drivers_license', 'umid', 'prc_id', 'postal_id'</code>	Government-issued IDs accepted for landlord verification.

3. Data Dictionary: Tables & Constraints

3.1 Table (Extends Supabase)

Column	Type	Nullable	Default	Description & Constraints
id PK FK	uuid	NO	-	References auth.users(id) ON DELETE CASCADE.
role	public.user_role	NO	'renter'	Role tier. Immutable by regular users via RLS.
full_name	text	NO	-	User display name. Defaults to email prefix if not supplied.
phone_number CHK	text	YES	NULL	Philippine phone format: ^+?[0-9]{10,15}\$.
avatar_url	text	YES	NULL	Public storage URL for user avatar.
bio	text	YES	NULL	User bio or landlord organization description.
is_suspended	boolean	NO	false	Administrative account freeze flag.
created_at / updated_at	timestamptz	NO	now()	Audit timestamps with automated moddatetime trigger.

3.2 Table (Anti-Scam Trust Layer)

Column	Type	Nullable	Default	Description & Constraints
id PK	uuid	NO	uuid_generate_v4()	Primary Key.
landlord_id FK	uuid	NO	-	References public.profiles(id) ON DELETE CASCADE.
id_type	public.kyc_id_type	NO	-	Submitted ID card type.
id_document_url	text	NO	-	Private storage object path to ID scan.
proof_of_ownership_url	text	YES	NULL	Private storage path to property title / utility bill.
status	public.kyc_status	NO	'pending'	Verification lifecycle: pending, verified, rejected.
reviewed_by FK	uuid	YES	NULL	References public.profiles(id) of reviewing Admin.
reviewed_at / rejection_reason	timestamptz / text	YES	NULL	Audit timestamp and mandatory rejection reason.

4. Automated Triggers & Security Definer Functions

4.1 User Onboarding Trigger:

Automatically executes whenever a user registers through Supabase Auth, extracting user metadata and enforcing the anti-privilege escalation firewall:

```
CREATE OR REPLACE FUNCTION public.handle_new_user()
RETURNS TRIGGER
LANGUAGE plpgsql
SECURITY DEFINER
SET search_path = public, auth, extensions
AS 104694
DECLARE
    requested_role TEXT;
    assigned_role public.user_role;
    parsed_full_name TEXT;
BEGIN
    requested_role := lower(COALESCE(NEW.raw_user_meta_data->>'role', 'renter'));

    -- Anti-Privilege Escalation Firewall: Admin cannot be requested via public signup
    IF requested_role = 'landlord' THEN
        assigned_role := 'landlord'::public.user_role;
    ELSE
        assigned_role := 'renter'::public.user_role;
    END IF;

    parsed_full_name := COALESCE(
        NULLIF(trim(NEW.raw_user_meta_data->>'full_name'), ''),
        NULLIF(trim(NEW.raw_user_meta_data->>'name'), ''),
        split_part(NEW.email, '@', 1)
    );

    INSERT INTO public.profiles (id, role, full_name, avatar_url, phone_number)
    VALUES (
        NEW.id,
        assigned_role,
        parsed_full_name,
        NEW.raw_user_meta_data->>'avatar_url',
        NEW.raw_user_meta_data->>'phone_number'
    );

    RETURN NEW;
END;
104694;
```

5. Row Level Security (RLS) Policy Matrix

Table	Operation	Permitted Roles	Policy Rule
profiles	SELECT	Public (all)	Public profiles are readable by everyone (USING (TRUE)).
profiles	UPDATE	Self	User can update own profile (auth.uid() = id); role/suspended changes blocked.
profiles	ALL	Admin	Admins have full access via public.is_admin().
kyc_verifications	SELECT	Landlord (own) / Admin	Only submitting landlord (auth.uid() = landlord_id) or admin can view KYC docs.
kyc_verifications	INSERT	Landlord	Only landlords can submit KYC verification documents for their own account.
kyc_verifications	UPDATE	Admin only	Only platform admins can approve or reject KYC verification requests.

6. Deliverables & Verification Sign-Off

- **✓ SQL Migration:** supabase/migrations/20260929000001_users_and_profiles.sql
- **✓ TypeScript Types:** src/types/database.ts (Zero compiler errors via `pnpm tsc --noEmit`)
- **✓ Documentation:** docs/users-and-profiles-schema.md
- **✓ Security Audit:** Passed with zero critical vulnerabilities by Senior Dev Auditor.